

FICHE D'INCIDENT

INC-2026-001

Ransomware avec exfiltration de données de santé Double extorsion

SÉVÉRITÉ	STATUT	DÉTECTION	CLÔTURE
CRITICAL	Résolu	19/04/2026 14h20	22/06/2026 15h46

ATTENTION - Obligation RGPD Art. 33 : Des données de santé ont été exfiltrées. Une notification à la CNIL est obligatoire dans un délai de 72 heures suivant la prise de connaissance de la violation.

1. Résumé Exécutif

La compromission initiale d'Iron4Software a eu lieu le 07 mars 2026, via une chaîne d'attaque en quatre étapes : exploitation d'un webshell PHP sur le serveur web Ubuntu (192.168.3.11), pivot réseau vers le LAN interne, brute-force SMB du compte Administrateur, et déploiement d'un ransomware avec exfiltration préalable d'un dump de base de données de production d'un client du secteur de la santé. L'incident n'a été formellement détecté que le 19 avril 2026 à 14h20, lors de la campagne de re-validation Phase 5, lorsque le dashboard SOC Iron4Software – SOC Supervision a déclenché simultanément trois alertes Critical dans Splunk : intrusion WAN, brute-force sur le Contrôleur de Domaine, et activité ransomware sur les données sensibles.

Les actions de réponse à incident (contention, éradication, récupération) ont été menées et documentées conformément au Playbook IR Iron4Software. L'incident implique une violation de données de santé soumises au RGPD, nécessitant une notification à la CNIL sous 72 heures conformément à l'Article 33 du règlement.

2. Systèmes Affectés

Système	Adresse IP	Rôle	Impact
Ubuntu Web	192.168.3.11	Serveur web Apache	Webshell déposé, utilisé comme point d'entrée initial
Windows Server 2019	192.168.3.10	Contrôleur de Domaine AD	Compromission totale – brute-force, RDP, ransomware
pfSense	192.168.50.7	Pare-feu périmétrique	Règle WAN permissive exploitée pour le pivot réseau

3. Source Attaquante

IP source	192.168.50.5
Machine identifiée	Kali Linux
Réseau source	WAN (192.168.50.0/24)
Tentatives bloquées sur WAN	2 084

4. Indicateurs de Compromission (IoC)

Type	Valeur	Description
IP	192.168.50.5	Machine attaquante Kali Linux
Fichier	/var/www/html/shell.php	Webshell PHP utilisé dès le 07/03/2026 à 10h03 (logs Apache)
Commandes RCE	cmd=whoami, cmd=ip+a, cmd=ping	Charges utiles exécutées via le webshell

Compte compromis	IRON4SOFTWARE\Administrateur	Credential volé via brute-force SMB (MDP : Admin123)
Fichier exfiltré	Dump_SQL_IronSuite_Clinique_StJean_PROD.bak	Données santé copiées via presse-papiers RDP vers Kali
Artefact ransomware	LOCKED-Dump_SQL_IronSuite_Clinique_StJean_PROD.bak	Fichier original renommé et chiffré dans C:\PRIVATE - NE PAS RENTRER !
Artefact ransomware	PAY-BITCOIN!.txt	Note de rançon Bitcoin déposée dans C:\PRIVATE - NE PAS RENTRER !
Event ID	4625 (Logon_Type=3)	Échecs d'authentification en masse - brute-force SMB
Event ID	4624 (Logon_Type=3)	Succès d'authentification réseau - confirmation compromission
Event ID	4663	Accès aux objets fichiers - activité ransomware sur dossier PRIVATE

5. Chronologie de l'Attaque (Kill Chain MITRE ATT&CK;)

Horodatage	Technique MITRE	Description
07/03/2026 10h03	T1190 – Exploit Public-Facing App	Dépôt du webshell shell.php sur le serveur Apache Ubuntu (192.168.3.11)
07/03/2026 10h03 – 08/03/2026 09h51	T1059 – Command & Scripting Interpreter	Exécution de commandes RCE via le webshell (whoami, ip a, ping) – reverse shell bash établi le 08/03 à 09h51
07/03/2026 10h03	T1090 – Proxy / Pivot	Route statique ajoutée sur Kali exploitant la règle WAN Allow All pour atteindre le LAN 192.168.3.0/24
07/03/2026 11h06	T1110.001 – Brute Force	Début du brute-force SMB via CrackMapExec depuis 192.168.50.5 – succès à 11h49 avec le mot de passe Admin123
07/03/2026 11h49 – 12h11	T1021.001 – Remote Desktop Protocol	Authentification Administrateur réussie à 11h49 – connexion RDP interactive établie à 12h11 sur WIN-HKVM4FR00PS
07/03/2026 (cours session RDP)	T1048 – Exfiltration Over C2 Channel	Exfiltration du dump SQL Clinique St-Jean via presse-papiers RDP vers Kali – heure exacte non disponible (audit NTFS non encore activé en Phase 2)
07/03/2026 (cours session RDP)	T1486 – Data Encrypted for Impact	Chiffrement et renommage du fichier en LOCKED-Dump_SQL_IronSuite_Clinique_StJean_PROD.bak, dépôt note de rançon PAY-BITCOIN! – heure exacte non disponible (audit NTFS non encore activé)
19/04/2026 14h20	Détection SIEM	3 alertes Critical Splunk déclenchées simultanément lors de la re-attaque Phase 5 – ouverture INC-2026-001

6. Chronologie de la Réponse à Incident

Horodatage	Phase IR	Action menée
19/04/2026 14h20	Triage	Détection des 3 alertes Critical sur le dashboard SOC – ouverture INC-2026-001
22/06/2026 15h00	Contention	Blocage IP 192.168.50.5 sur WAN pfSense – règle IR INC-2026-001 – Blocage IP attaquante Kali
22/06/2026 15h05	Contention	Isolation du Windows Server 192.168.3.10 – règle LAN IR INC-2026-001 – Isolation Windows Server compromis
22/06/2026 15h10	Contention	Désactivation du compte IRON4SOFTWARE\Administrateur dans Active Directory
22/06/2026 15h15	Éradication	Suppression du webshell /var/www/html/shell.php sur Ubuntu Web
22/06/2026 15h20	Éradication	Vérification répertoire web – aucune backdoor supplémentaire détectée
22/06/2026 15h25	Éradication	Vérification Planificateur de tâches Windows – aucune tâche suspecte identifiée

22/06/2026 15h30	Éradication	Reset mot de passe Administrateur – Admin123 remplacé par Iron4SOC@2026!
22/06/2026 15h35	Éradication	Réactivation du compte Administrateur avec le nouveau mot de passe fort
22/06/2026 15h40	Récupération	Levée de l'isolation réseau – règle LAN désactivée (conservée pour traçabilité)
22/06/2026 15h43	Récupération	Suppression des artefacts ransomware LOCKED-INFO!!!.txt et PAY BITCOIN!!!.txt – confirmé par Event ID 4663 à 15h43:23
22/06/2026 15h45	Récupération	Constat : C:\BACKUPS_SECURE vide – aucune sauvegarde automatisée en place
22/06/2026 15h46	Récupération	Restauration manuelle du fichier Dump_SQL_IronSuite_Clinique_StJean_PROD.bak dans dossier PRIVATE
22/06/2026 15h46	Clôture	Dossier PRIVATE restauré – toutes les mesures de contention et éradication validées – incident clos

7. Analyse de l'Impact

TECHNIQUE	RGPD / DATA	OPÉRATIONNEL
- Compromission totale du Contrôleur de Domaine WIN-HKVM4FR00PS - Credentials Administrateur du domaine exposés - Données sensibles accessibles et chiffrées sur le serveur	- Fichier exfiltré : Dump_SQL_IronSuite_Clinique_StJean_PROD.bak - Nature : données de santé (Clinique St-Jean) - Notification CNIL sous 72h obligatoire (RGPD Art. 33) - Risque double extorsion : menace de publication	- Indisponibilité du Windows Server pendant la contention - Interruption des services Active Directory - Aucune sauvegarde opérationnelle disponible (C:\BACKUPS_SECURE vide)

8. Causes Racines Identifiées

Faible applicative	Webshell shell.php accessible publiquement depuis le WAN via le port 80
Architecture réseau permissive	Règle WAN Allow All sur pfSense permettant le pivot direct depuis l'extérieur vers le LAN
Politique de mots de passe défaillante	Mot de passe Administrateur trivial (Admin123) sans politique de complexité
Absence de verrouillage de compte	Aucun seuil de verrouillage configuré - brute-force SMB illimité possible
Absence de sauvegarde opérationnelle	Zone C:\BACKUPS_SECURE créée structurellement mais jamais alimentée automatiquement
Canaux RDP non restreints	Presse-papiers et redirection de lecteurs RDP activés par défaut - exfiltration facilitée

9. Mesures Correctives Appliquées

Suppression du webshell shell.php sur Ubuntu Web	✓ Appliqué
Blocage IP attaquante 192.168.50.5 sur pfSense WAN	✓ Appliqué
Reset mot de passe Administrateur (Iron4SOC@2026!)	✓ Appliqué
Isolation puis remise en production contrôlée du Windows Server	✓ Appliqué
Restauration manuelle des données du dossier PRIVATE	✓ Appliqué

10. Recommandations Post-Incident

Priorité	Recommandation
Critique	Mettre en place une politique de sauvegarde automatisée et testée régulièrement sur C:\BACKUPS_SECURE
Critique	Notifier la CNIL sous 72h en raison de l'exfiltration de données de santé (RGPD Art. 33)
Haute	Bloquer les fonctionnalités de presse-papiers et de redirection de lecteurs RDP via GPO
Haute	Mettre en place une politique de mots de passe complexes et un seuil de verrouillage AD strict
Moyenne	Implémenter une DMZ pour isoler le serveur web du LAN interne
Moyenne	Déployer un EDR sur les endpoints pour détecter les comportements ransomware en temps réel
Basse	Mettre en place une rotation régulière des credentials Administrateur de domaine